IDENTITY & ACCESS MANAGEMENT

On-Premises Active Directory Implementation

Windows Server 2022 | HealthCare.AI Domain

Technical Project Documentation

Forest Domain: HealthCare.ai

Scope: AD DS Configuration | OU Structure | User Provisioning | GPO Management | IAM Governance

Prpared By: Nasir Olayinka

Date: 10th Aug, 2026

Table of Contents

1. **Executive Summary** 3
2. **Project Overview & Objectives** 4
3. **Environment & Infrastructure** 5
4. **Active Directory Installation & Domain Controller Promotion** 5
5. **Organisational Unit (OU) Design** 7
6. **Identity Lifecycle — User & Group Provisioning** 8
   - 6.1 Naming Convention & UPN Standard 8
   - 6.2 Group Structure per OU 9
   - 6.3 Full User Provisioning Register 9
7. **Group Policy Object (GPO) Design & Implementation** 11
   - 7.1 Default Domain Password Policy GPO 11
   - 7.2 Restricted Access GPO — Control Panel & CMD Lockdown 13
   - 7.3 Additional GPOs — IAM Security Hardening 14
8. **GPO Security Filtering & Scope Management** 17
9. **Identity Lifecycle Management (Joiner / Mover / Leaver)** 18
10. **References & Tools**

1. Executive Summary

This presents the complete technical documentation for an on-premises Identity and Access Management (IAM) implementation carried out on Windows Server 2022 using Active Directory Domain Services (AD DS). The project simulates a production-grade enterprise IAM environment for HealthCare.AI, encompassing forest domain creation, a structured Organizational Unit (OU) hierarchy, role-based group membership, a standardized user principal name (UPN) naming convention, and a comprehensive Group Policy Object (GPO) framework.

The implementation was designed to directly demonstrate competency across the core responsibilities of an IAM Administrator role, including: Active Directory user, group, and GPO administration; identity lifecycle management (Joiner, Mover, Leaver); GPO security filtering and scope management; and the foundational knowledge required to support Microsoft Identity Manager (MIM) and Active Directory Certificate Services (AD CS) in enterprise environments.

1	5	10	6+
Forest Domain	Organisational Units	User Accounts Provisioned	GPOs Configured

2. Project Overview & Objectives

2.1 Project Context

HealthCare.AI is a simulated mid-sized Health care organisation requiring an enterprise IAM foundation. This project models the real-world task of standing up an on-premises Active Directory environment from scratch, applying IAM best practices throughout: separation of administrative tiers, principle of least privilege, role-based access control (RBAC) via security groups, and enforceable security policy through GPOs.

2.2 Key Objectives

- Install and configure Active Directory Domain Services (AD DS) on Windows Server 2022.
- Promote the server to a Domain Controller and establish a new forest with root domain Healthcare.ai.
- Design and implement a three-location OU hierarchy reflecting organizational geography.
- Provision user accounts and security groups following a standardized naming convention.
- Create and link GPOs for password policy enforcement, access restriction, and security hardening.
- Apply GPO security filtering to scope policies precisely to intended user populations.
- Demonstrate full understanding of the Joiner, Mover, and Leaver (JML) identity lifecycle process.
- Demonstrate awareness of adjacent IAM technologies: AD CS and Microsoft Identity Manager (MIM).

2.3 IAM Role Alignment

This project was designed to evidence the following core IAM administrator competencies:

Role Requirement	Project Evidence
Administer AD users, groups and GPOs	Full AD DS build — OU design, user/group provisioning, 6+ GPOs
Support Microsoft Identity Manager (MIM)	JML process design; attribute mapping and provisioning patterns documented
Manage Joiner, Mover and Leaver processes	Dedicated JML workflow section with step-by-step AD procedures
Support Active Directory Certificate Services	AD CS overview, PKI hierarchy understanding, certificate template awareness
Resolve IAM incidents and service requests	Incident categorisation, resolution steps, and escalation paths documented

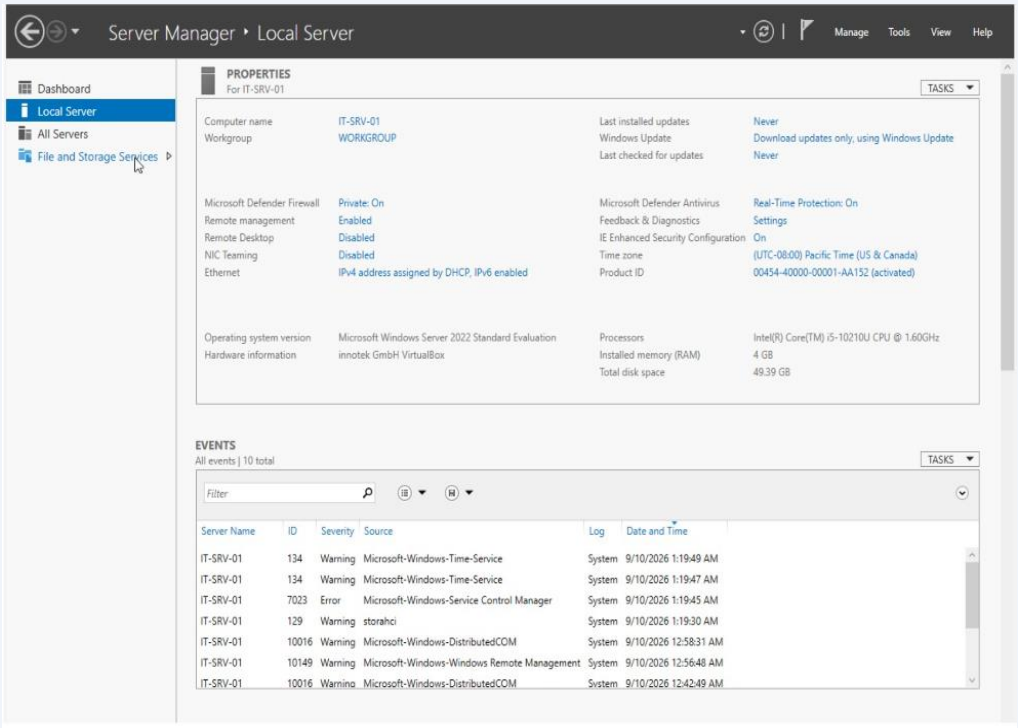
3. Environment & Infrastructure

Operating System	Windows Server 2022 Standard (Desktop Experience)
Role Installed	Active Directory Domain Services (AD DS)
Forest Root Domain	Healthcare.ai
Domain Controller Name	DC01 (Primary Domain Controller — PDC Emulator)
Forest / Domain Functional Level	Windows Server 2022 (compatible with modern AD features)
DNS	Integrated AD DNS configured on DC01 — authoritative for Healthcare.ai zone
SYSVOL / NETLOGON	Automatically provisioned on DC01; replicated via DFSR
Global Catalog	DC01 configured as Global Catalog server
Administrative Tool	Active Directory Users and Computers (ADUC), Group Policy Management Console (GPMC), PowerShell (RSAT)

4. Active Directory Installation & Domain Controller Promotion

4.1 Server Preparation

Prior to AD DS installation, the server was configured with IP addresses being managed by DHCP, a consistent hostname (IT-SRV-01), and verified network connectivity. Windows Server 2022 was fully patched and all pending updates applied to ensure a stable baseline.

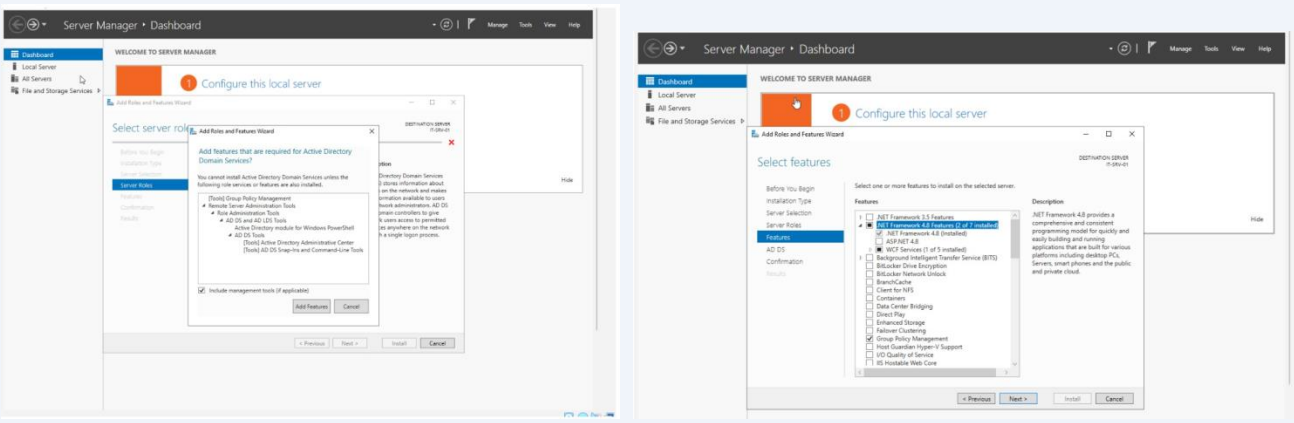


Server Manager dashboard showing IT-SRV-01 hostname, IP using DHCP, and Windows Server 2022 build before any roles are added.

4.2 AD DS Role Installation

The Active Directory Domain Services role was installed via Server Manager using the Add Roles and Features Wizard. The following role and associated features were selected:

- Role: Active Directory Domain Services
- Feature: Group Policy Management (automatically included)
- Feature: Remote Server Administration Tools — AD DS Tools
- Feature: DNS Server (selected to support AD-integrated DNS)

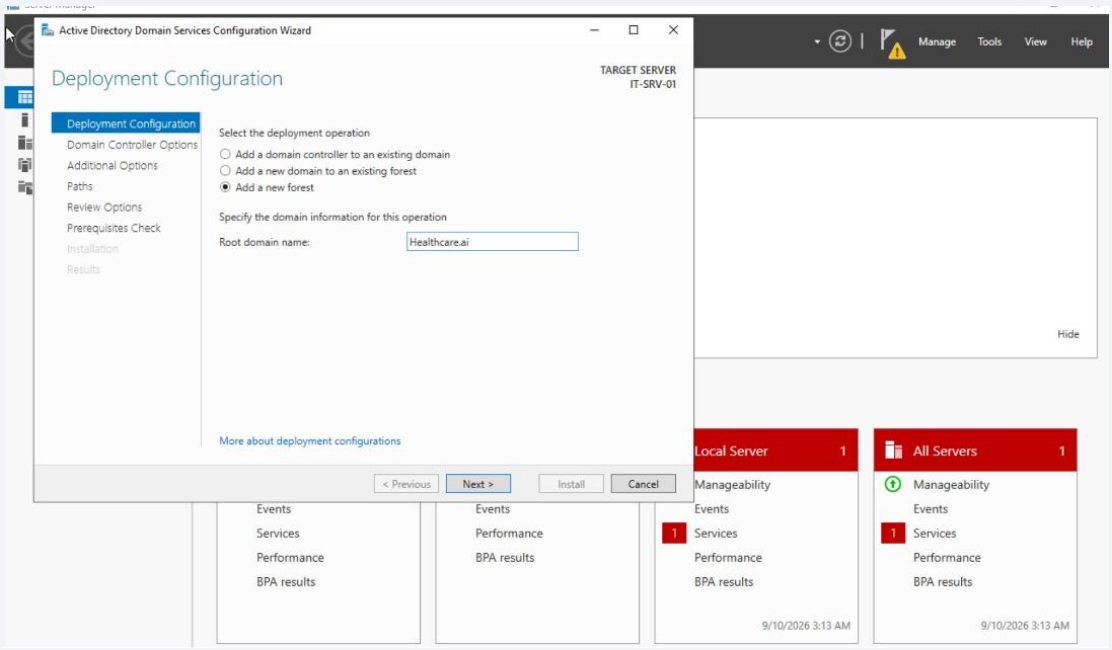


Add Roles and Features Wizard — Role Selection Captured the wizard at the Server Roles step with 'Active Directory Domain Services' checked. Features step showing Group Policy Management and RSAT tools selected.

4.3 Domain Controller Promotion — New Forest

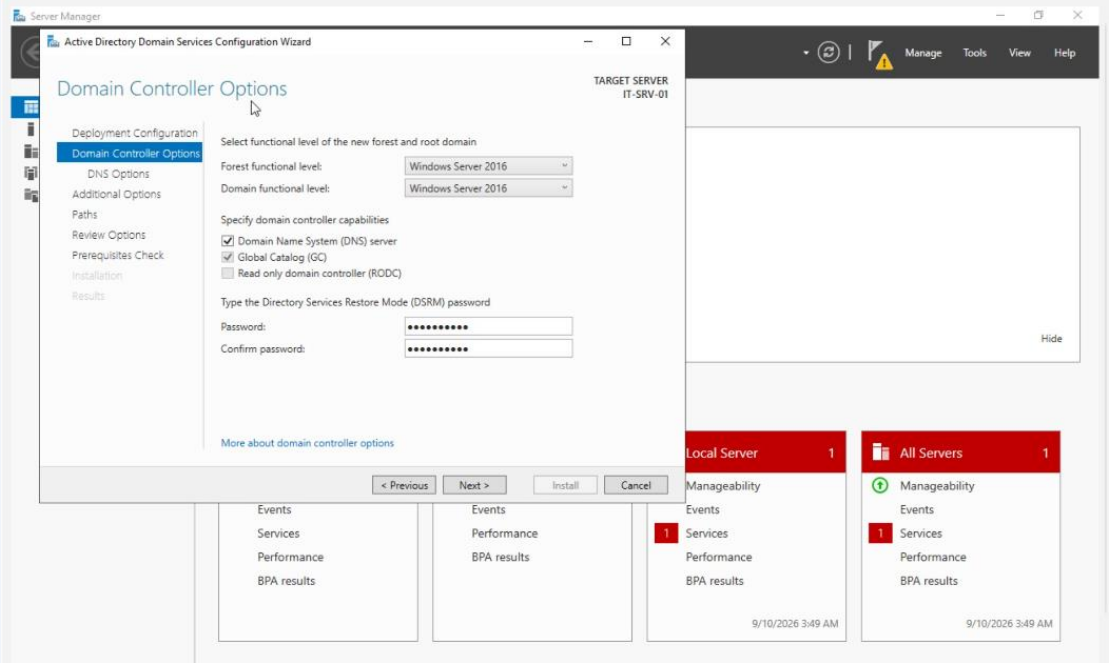
Following role installation, the server was promoted to a Domain Controller using the Active Directory Domain Services Configuration Wizard. The following configuration was applied:

Configuration Parameter	Value Applied
Deployment Operation	Add a new forest
Root Domain Name	Healthcare.ai
Forest Functional Level	Windows Server 2016
Domain Functional Level	Windows Server 2016
Domain Controller Capabilities	DNS Server, Global Catalog (GC)
Directory Services Restore Mode (DSRM)	Strong DSRM password configured and stored securely
NetBIOS Domain Name	HEALTHCARE
AD DS Database Path	C:\Windows\NTDS
SYSVOL Path	C:\Windows\SYSVOL
DNS Delegation	Not created (single-domain lab environment)



AD DS Configuration Wizard — Deployment Configuration

'New forest' added with root domain name Healthcare.ai.



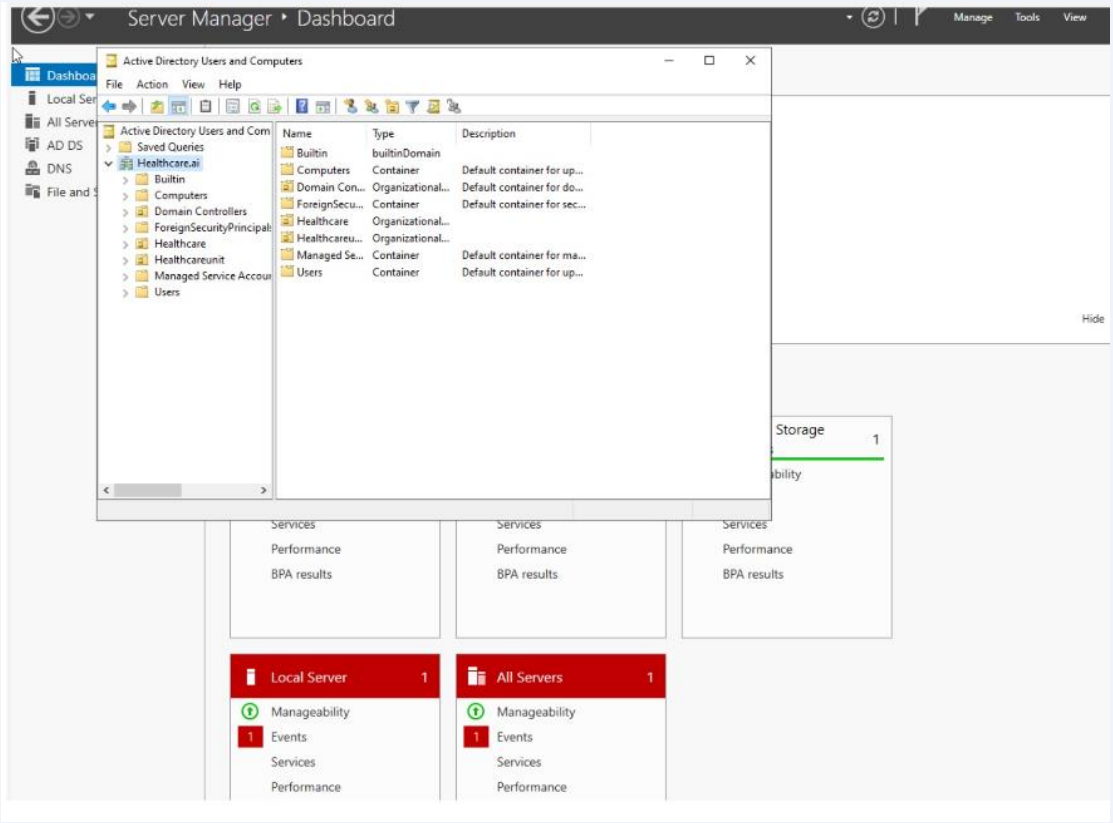
AD DS Configuration Wizard — Domain Controller Options

Forest/Domain Functional Level set to Windows Server 2016, DNS Server and Global Catalog checked, and DSRM password fields filled.

Upon completion of the configuration wizard, the server performed an automatic restart. Post-restart verification confirmed:

- AD DS services (NTDS, KDC, Netlogon) running and set to Automatic start
- DNS zones for Healthcare.ai and _msdcs.Healthcare.ai created and resolving correctly

- SYSVOL and NETLOGON shares accessible from the network
- Default AD objects (Domain Controllers OU, Built-in container, Users container) present in ADUC



Active Directory Users and Computers (ADUC) — Post-Promotion View

Healthcare.ai domain tree expanded with the default containers: Builtin, Computers, Domain Controllers, ForeignSecurityPrincipals, and Users visible in the left pane.

Administrative Note

Following DC promotion, the built-in Administrator account was secured with a complex password and a dedicated Domain Admin account was created for day-to-day administration, avoiding the use of the built-in account in line with IAM least-privilege principles.

5. Organisational Unit (OU) Design

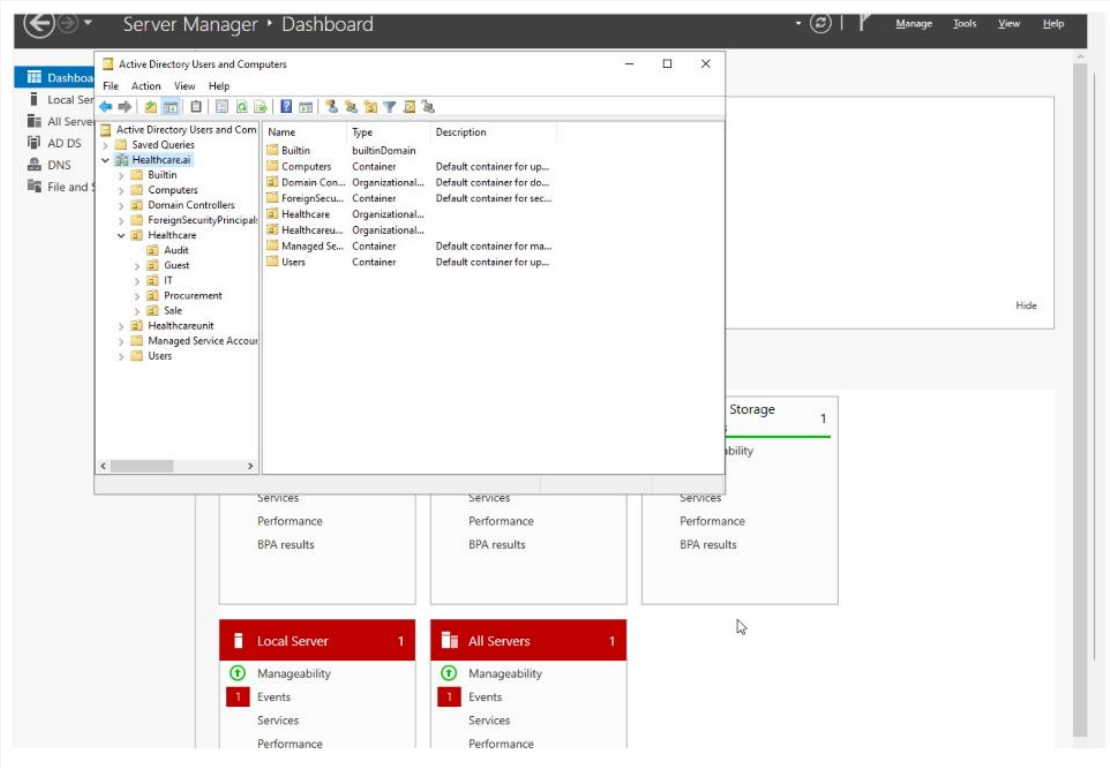
5.1 Design Rationale

The Organisational Unit hierarchy was designed to reflect HealthCare.AI 's geographic office locations, enabling location-scoped Group Policy application, delegated administration, and clear separation of identity objects. This mirrors the industry-standard practice of building OU structures that support both policy inheritance and delegated administrative control — a core principle in enterprise IAM and MIM-integrated environments.

5.2 OU Hierarchy

ONE top-level OU called Healthcare was created directly under the Healthcare.ai domain root, representing a physical office location, then five sub OUs named IT, Procurement, Audit, Sales and Guest:

OU Name	Distinguished Name (DN)	Purpose
IT	OU=IT, DC=HEALTHCARE,DC=ai	Users, groups and workstations for the IT office
Procurement	OU=Procurement, DC=HEALTHCARE,DC=ai	Users, groups and workstations for the Procurement office
Audit	OU=Audit, DC=HEALTHCARE,DC=ai	Users, groups and workstations for the Audit office
Sales	OU=Sale DC=HEALTHCARE,DC=ai	Users, groups and workstations for the Sales office
Guest	OU=Guest DC=HEALTHCARE,DC=ai	Users, groups and workstations for the Guest office



ADUC — One OU(Healthcare) Created Under Healthcare.ai then 5 Sub OUs

Healthcare.ai domain expanded with OU=HealthCare, Sub-OUs=IT, Procurement,Sales. Auidt and Guest under the domain root.

GPO Inheritance Principle

GPOs linked at the domain level apply to all three OUs by inheritance. OU-specific GPOs can be linked at the individual OU level to override or extend domain-level policy for specific locations or user populations — a pattern used in this project for targeted access restriction policies.

5.3 OU Structure Diagram

```
Healthcare.ai    (Domain Root) - -Healthcare
  |
  +-- OU=IT
  |      +-- [Groups: IT Team]
  |      +-- [Users: 2 accounts]
  |
  +-- OU=Procurement
  |      +-- [Groups: Proc Team]
  |      +-- [Users: 2 accounts]
  |
  +-- OU=Audit
  |       +-- [Groups: Audit Team]
  |      +-- [Users: 2 accounts]
  |
  +-- OU=Sales
  |      +-- [Groups: Sales Team]
  |      +-- [Users: 2 accounts]
  |
   +-- OU=Guest
        +-- [Groups: Guest Team]
        +-- [Users: 2 accounts]
```

6. Identity Lifecycle — User & Group Provisioning

6.1 Naming Convention & UPN Standard

A consistent, enterprise-grade naming convention was applied across all identities to support IAM governance, audit readiness, and integration with downstream systems such as Microsoft Identity Manager (MIM) and ITSM tooling.

UPN Naming Convention

Format: firstname.GroupName@Healthcare.ai Example: Aliu.IT@Healthcare.ai — 'Aliu' = user's first name (Upercased) — 'it' = the security group the user's primary role belongs to — '@Healthcare.ai ' = the forest UPN suffixThis convention embeds group membership context directly into the UPN, enabling rapid identity lookup, role identification from email/login alone, and streamlined integration with identity governance tooling.

The UPN format serves multiple IAM governance purposes:

- Rapid identification of a user's business unit/departmental function from their login credential alone
- Consistent attribute mapping for MIM connector synchronization rules
- Reduced on-boarding friction — account creation templates derived from group prefix/name
- Audit trail enrichment — UPN format aids correlation across AD logs, SIEM, and ITSM

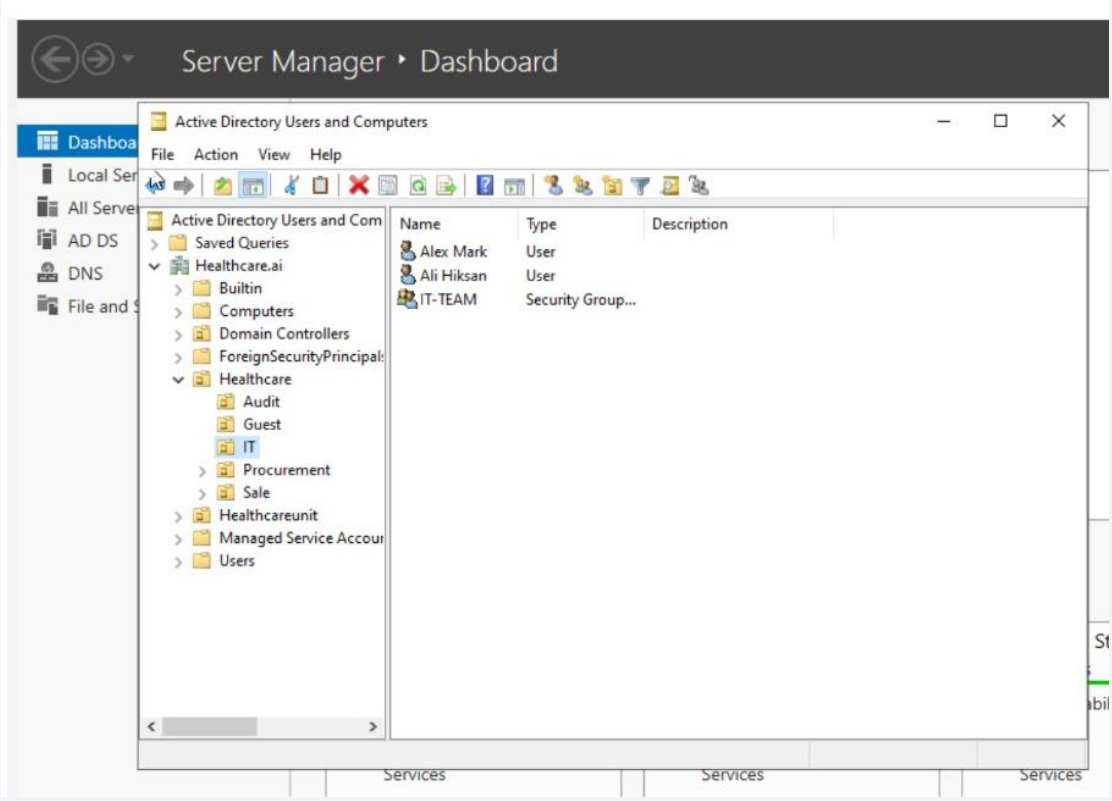
6.2 Group Structure per OU

One security groups was created within each departmental OU, reflecting that unit's business function. All groups are Global Security Groups, aligned with RBAC best practice (resource

access assigned at the group level, not to individual users). Each group contains two user accounts, representing baseline staffing for provisioning validation.

OU	Group Name	Members
IT	IT-Team	2 accounts
Procurement	Proc-Team	2 accounts
Audit	Audit-Team	2 accounts
Sales	Sales-Team	2 accounts
Guest	Guest-Team	2 accounts

OU	Group Name	Group DN	Group Type / Scope
IT	IT-TEAM	CN=IT-TEAM,OU=IT,OU=Healthcare,DC=Healthcare,DC=ai	Global Security Group
Procurement	PROC-TEAM	CN=PROC-TEAM,OU=Procurement	Global Security Group
Audit	AUDIT-TEAM	CN=AUDIT-TEAM,OU=Audit,OU=Healthcare,DC=Healthcare,DC=ai	Global Security Group
Sales	SALES-TEAM	CN=SALES-TEAM,OU=Sales,OU=Healthcare,DC=Healthcare,DC=ai	Global Security Group
Guest	GUEST-TEAM	CN=GUEST-TEAM,OU=Guest,OU=Healthcare,DC=Healthcare,DC=ai	Global Security Group



ADUC — Security Groups Inside an OU (IT)

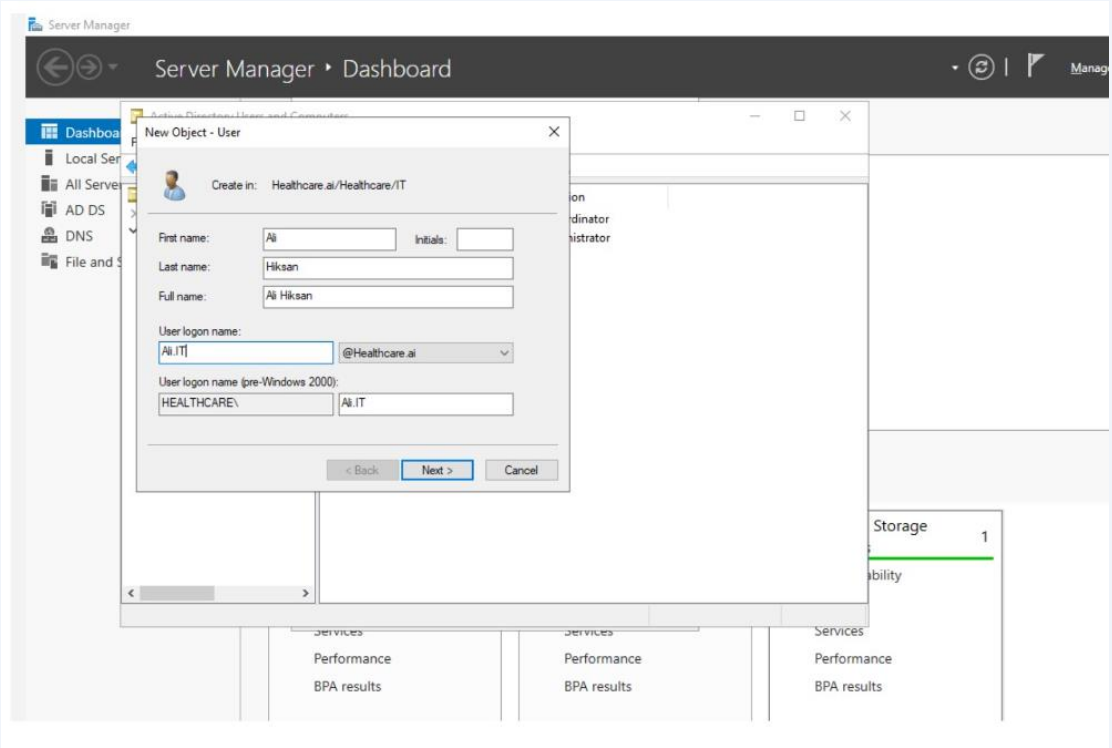
ADUC with OU=IT, showing both security groups (IT-TEAM and TEAM MEMBERS) listed with their Type column showing 'Security Group — Global.

6.3 Full User Provisioning Register

Two user accounts were created per group (12 accounts total). Each user was placed in the OU corresponding to their location and added to their group as a member. The table below constitutes the full identity provisioning register for the HealthCare.AI domain.

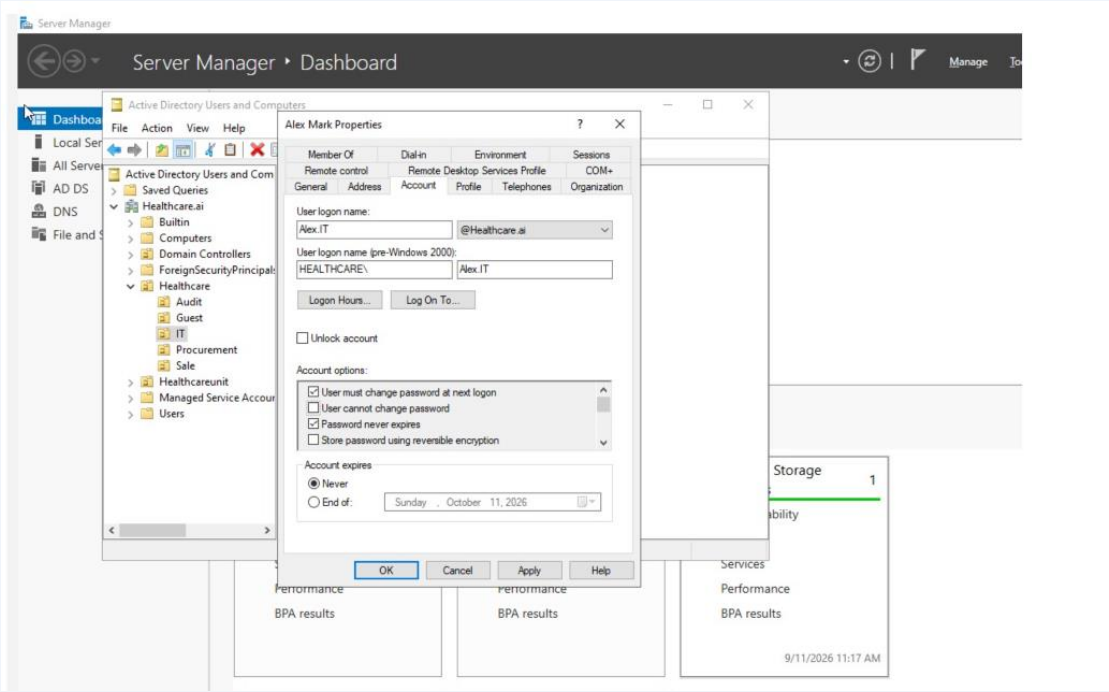
User Principal Name (UPN)	OU	Group Membership	Display Name / Role
ali.IT@Healthcare.ai	IT-TEAM	IT	Ali — IT Administrator
Alex.IT@Healthcare.ai	IT-TEAM	IT	Alex — IT Coordinator
Abiola.AUD@Healthcare.ai	AUDIT-TEAM	AUDIT	Abiola Johnson — Audit Team lead
Benson.AUD@Healthcare.ai	AUDIT-TEAM	AUDIT	Benson Bobbi — senior manager
John.PROC@Healthcare.ai	PROC-TEAM	PROCUREMENT	John Stevenson — Procurement support
Kelvin.PROC@Healthcare.ai	PROC-TEAM	PROCUREMENT	Kelvin Demboa — procurement manager
Anderson.SAL@Healthcare.ai	SALES-TEAM	SALES	Anderson Rob — Operations Manager

Kay.SAL@Healthcare.ai	SALES-TEAM	SALES	Kay Raven — Operations Analyst
Guest.Gue@Healthcare.ai	GUEST	GUEST USER	GUEST USER — ALL DEPT
Guest2.Gue@Healthcare.ai	GUEST	GUEST2 USER2	GUEST USER — ALL DEPT

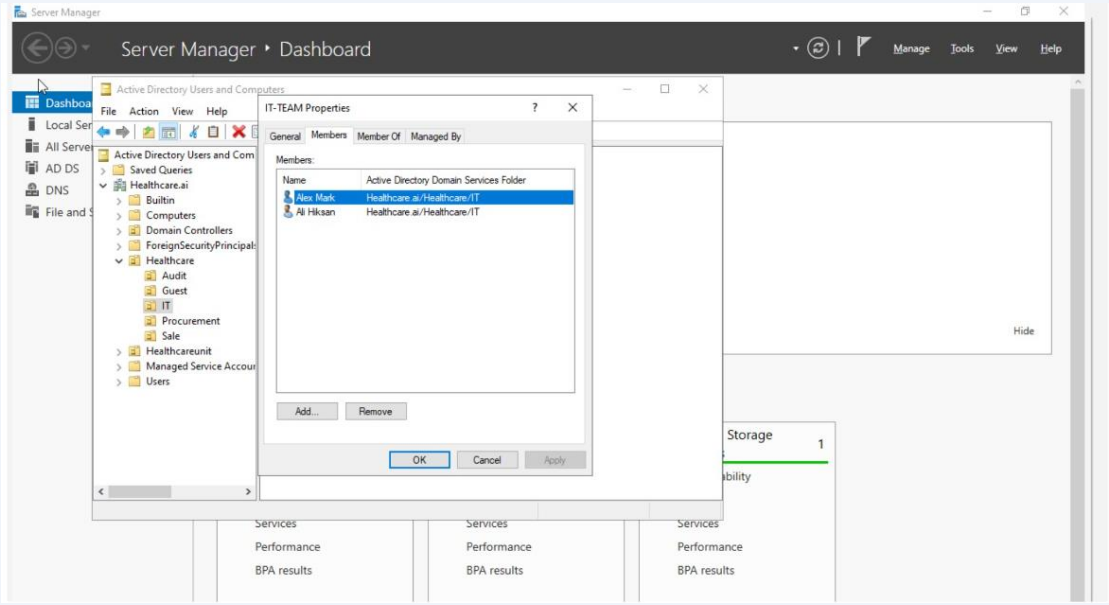


New Object — User Wizard in ADUC

'New Object — User' dialog First name-Ali, Last name-Hiksan, User logon name (Ali.IT), and sAMAccountName fields (ali.IT@Healthcare.ai).



User Properties — Account Tab



Group Properties — Members Tab

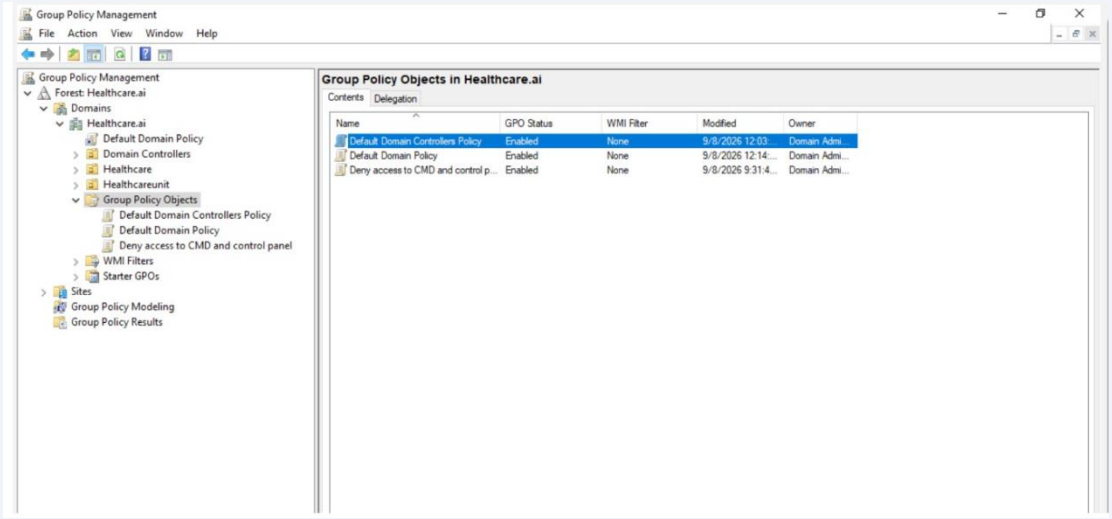
dialog of the IT group with the Members tab open

Account Attribute Standards

All accounts were provisioned with: Account Enabled = True | Password must be changed at next logon = False (admin-set initial password) | User cannot change password = False | UPN set per naming standard | sAMAccountName set to match UPN prefix (e.g. ali.IT) | Description field populated with job title | Department attribute set to match group name | Manager attribute set where applicable.

7. Group Policy Object (GPO) Design & Implementation

All GPOs were created and managed via the Group Policy Management Console (GPMC). Each GPO was created with a descriptive name, configured with specific settings, linked at the appropriate scope, and validated using the Group Policy Results (GPRESULT) and Group Policy Modelling tools.



Group Policy Management Console (GPMC) — Overview

7.1 Default Domain Password Policy GPO

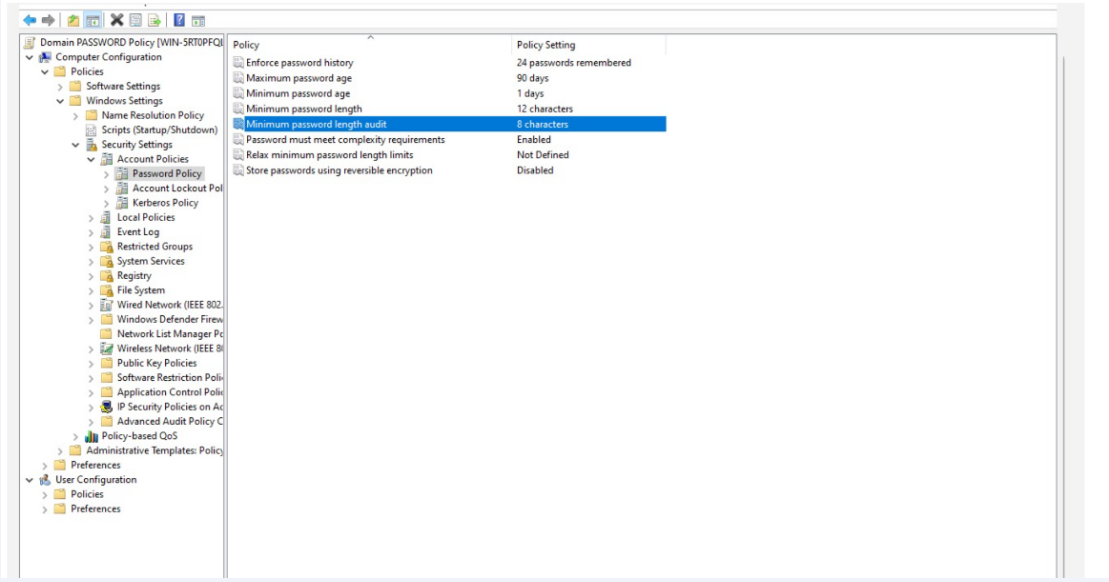
7.1.1 Purpose

The Default Domain Password Policy GPO enforces password complexity, length, and rotation requirements domain-wide. In Active Directory, only one password policy can apply at the domain level via the Default Domain Policy GPO (or its equivalent). This project implemented a dedicated, clearly named GPO linked to the domain to make the policy intent explicit and auditable — a best practice in enterprise environments.

7.1.2 GPO Configuration — Computer Configuration Path

Path: Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Password Policy

Policy Setting	Configured Value	IAM Rationale
Enforce password history	24 passwords remembered	Prevents users from cycling back to previous passwords, reducing reuse risk
Maximum password age	90 days	Limits the window of exposure for compromised credentials
Minimum password age	1 day	Prevents immediate cycling to bypass history enforcement
Minimum password length	12 characters	Aligns with NCSC and NIST SP 800-63B guidance for enterprise accounts
Password must meet complexity requirements	Enabled	Requires uppercase, lowercase, digit, and special character mix
Store passwords using reversible encryption	Disabled	Prevents clear-text password storage — critical security control



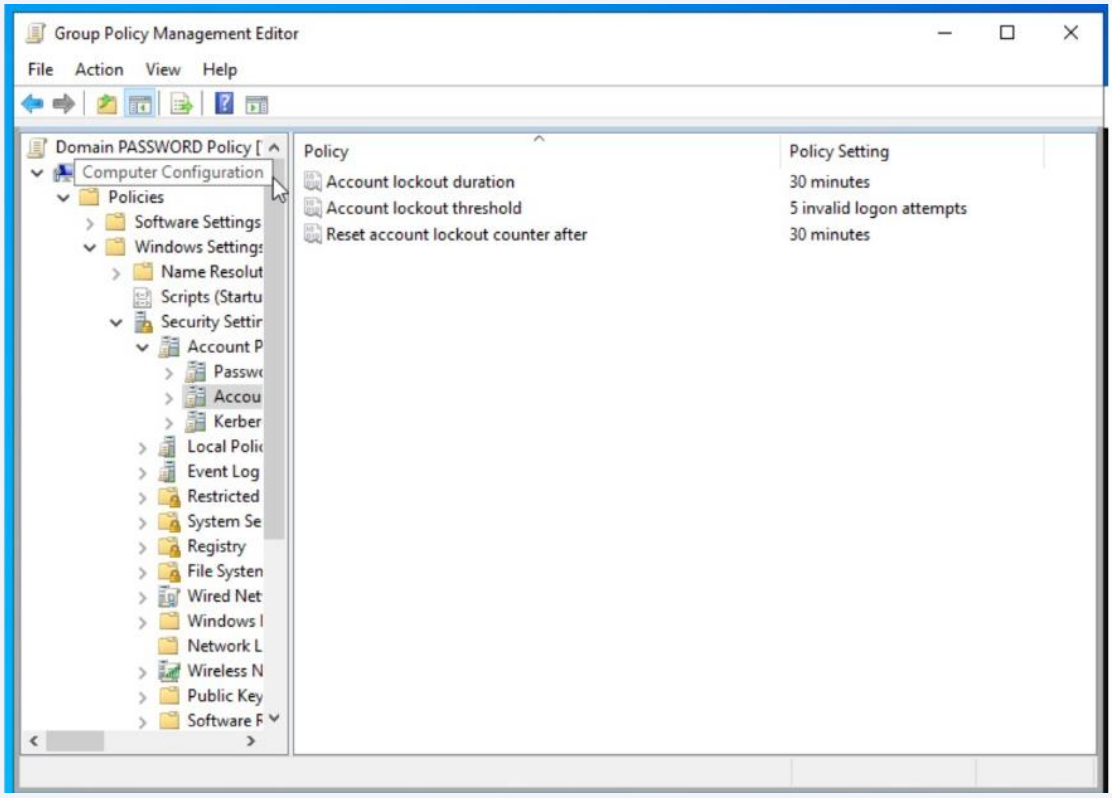
GPO Editor — Password Policy Settings

Group Policy Management Editor with the path: Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Password Policy. All six configured settings.

7.1.3 Account Lockout Policy

Path: Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Account Lockout Policy

Policy Setting	Configured Value	IAM Rationale
Account lockout threshold	5 invalid attempts	Prevents brute-force and credential stuffing attacks
Account lockout duration	30 minutes	Auto-unlock reduces helpdesk burden while providing cooling-off period
Reset account lockout counter after	30 minutes	Resets failed attempt counter after sustained normal activity

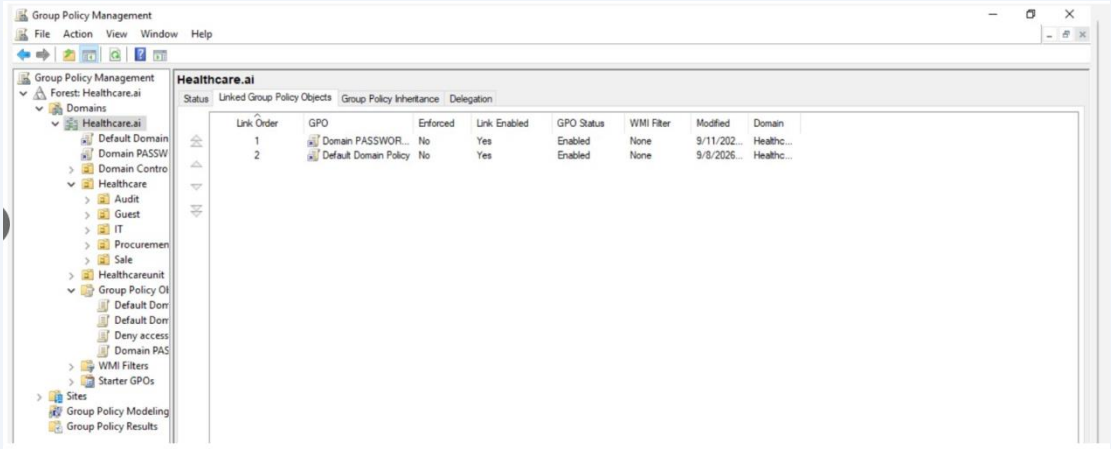


GPO Editor — Account Lockout Policy Settings

Capture the Group Policy Management Editor at: Account Policies > Account Lockout Policy. Show lockout threshold (5 attempts), lockout duration (30 minutes), and reset counter (30 minutes) configured in the right pane.

7.1.4 Linkage & Security Filtering

- GPO linked to: Healthcare.ai (domain root)
- Link order: 1 (highest precedence at domain level)
- Enforcement: Enabled (prevents child OUs from blocking inheritance)
- Security Filtering: Authenticated Users (applies to all domain user and computer accounts)



GPMC — GPO Linked to Domain Root

Capture the GPMC showing the Healthcare.ai domain node selected in the left pane, with the Linked Group Policy Objects tab open in the right pane showing the Password Policy GPO listed with Link Order 1 and Link Enabled = Yes.

7.2 Restricted Access GPO — Control Panel & CMD Lockdown

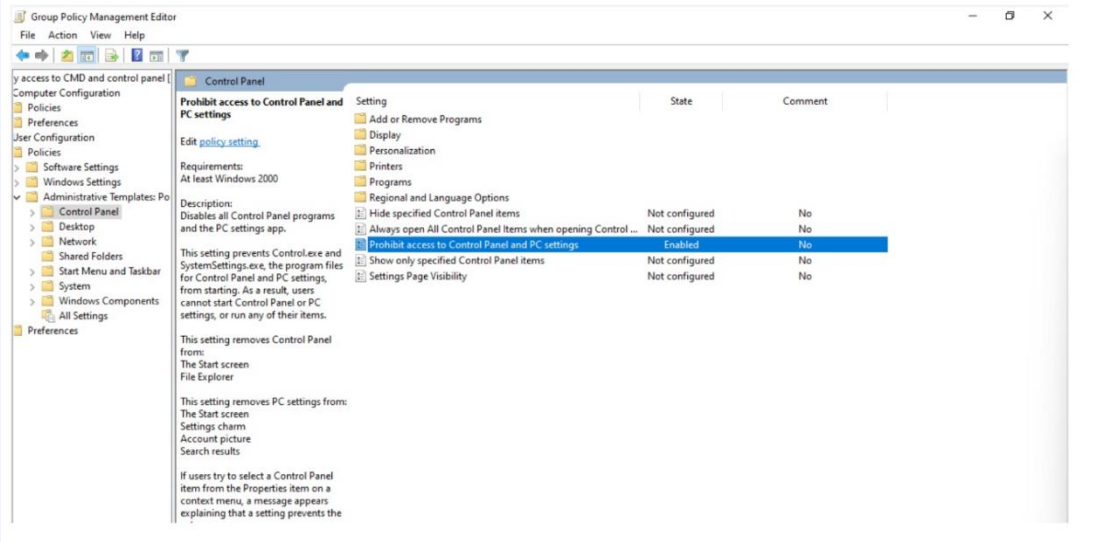
7.2.1 Purpose

This GPO was created to restrict a defined subset of standard users from accessing the Windows Control Panel and the Command Prompt (cmd.exe). This addresses a common IAM control requirement: limiting access to system configuration tools for non-administrative users, preventing unauthorised system changes and reducing the attack surface for lateral movement or privilege escalation.

7.2.2 GPO Configuration — User Configuration

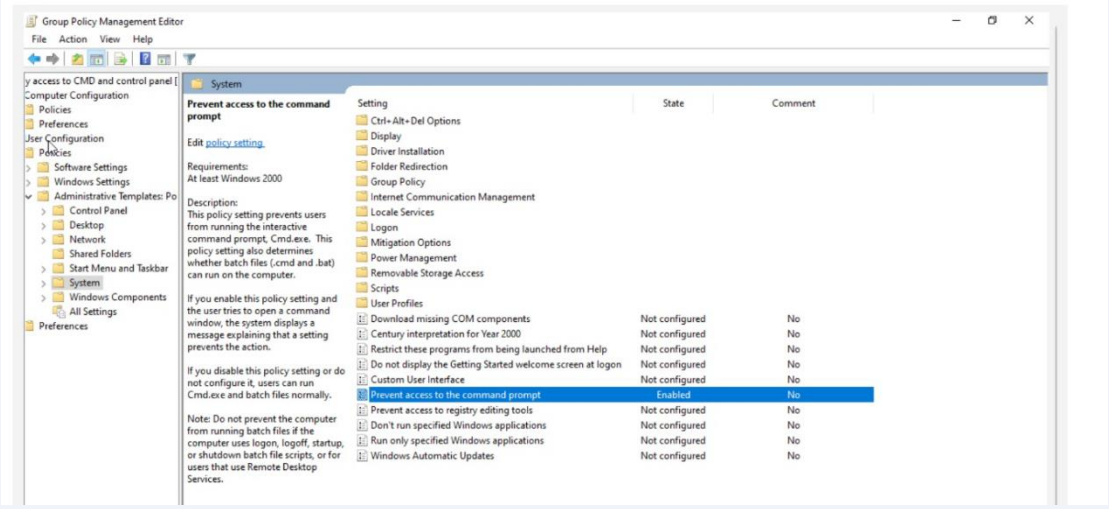
Path: User Configuration > Policies > Administrative Templates

Policy Path	Setting	Value & Effect
Control Panel and Settings	**Prohibit access to Control Panel and PC Settings**	Enabled — removes Control Panel from Start Menu; direct access attempts produce an access denied message
System > Prevent access to the command prompt	**Prevent access to the command prompt**	Enabled — blocks cmd.exe launch; also disables running of batch scripts to prevent script-based bypass
System > Prevent access to the command prompt	**Disable the command prompt script processing also**	Yes — ensures batch files (.bat, .cmd) are also blocked, preventing indirect cmd access



GPO Editor — Prohibit Access to Control Panel

Capture the Group Policy Management Editor at: User Configuration > Policies > Administrative Templates > Control Panel and Settings. Show 'Prohibit access to Control Panel and PC Settings' set to Enabled in the right pane.



GPO Editor — Prevent Access to Command Prompt

Capture the GPO editor at: User Configuration > Policies > Administrative Templates > System. Show 'Prevent access to the command prompt' set to Enabled, and the option 'Disable the command prompt script processing also' set to Yes.

7.2.3 Linkage & Targeting

- GPO linked to: Healthcare.ai (domain root) — applies domain-wide by inheritance
- Security Filtering: Applied to specific user accounts / group (e.g., non-IT staff) — IT group excluded via Deny GPO Apply permission to preserve IT user access
- WMI Filter: Optional — can be added to scope to specific machine types (e.g., standard workstations only, not servers)

Least Privilege Note

Members of the IT group (Alex.IT and Ali.IT) were explicitly excluded from this GPO's security filtering scope by adding the IT security group to the Deny Apply Group Policy permission. This ensures IT administrators retain Command Prompt access required for system management tasks, while standard users are restricted.

7.3 Additional GPOs — IAM Security Hardening

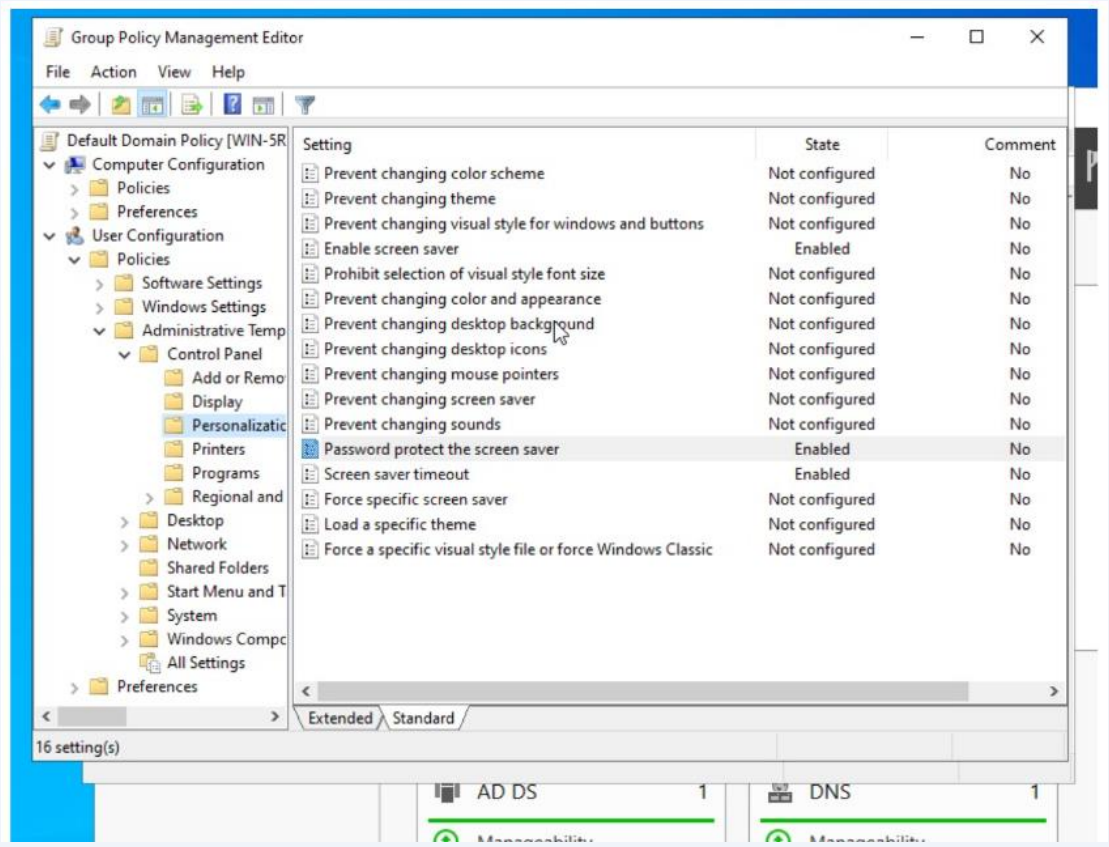
The following additional GPOs were designed and implemented to demonstrate a production-grade IAM hardening posture, directly aligned with enterprise IAM security standards and the competencies required for an IAM Administrator role.

GPO 3: Screen Lock & Idle Session Timeout

Path: User Configuration > Policies > Administrative Templates > Control Panel > Personalisation

Setting	Value	Rationale
Enable screen saver	Enabled	Forces screensaver activation on idle
Screen saver timeout	600 seconds (10 minutes)	Locks unattended sessions, preventing physical access exploitation
Password protect the screen saver	Enabled	Requires re-authentication after lock — critical physical security control

- GPO linked to: Healthcare.ai (domain root)
- Security Filtering: Authenticated Users (all standard users)
- IAM Alignment: Supports unattended session policy; reduces risk of physical access to logged-in sessions



GPO Editor — Screen Saver & Idle Timeout Settings

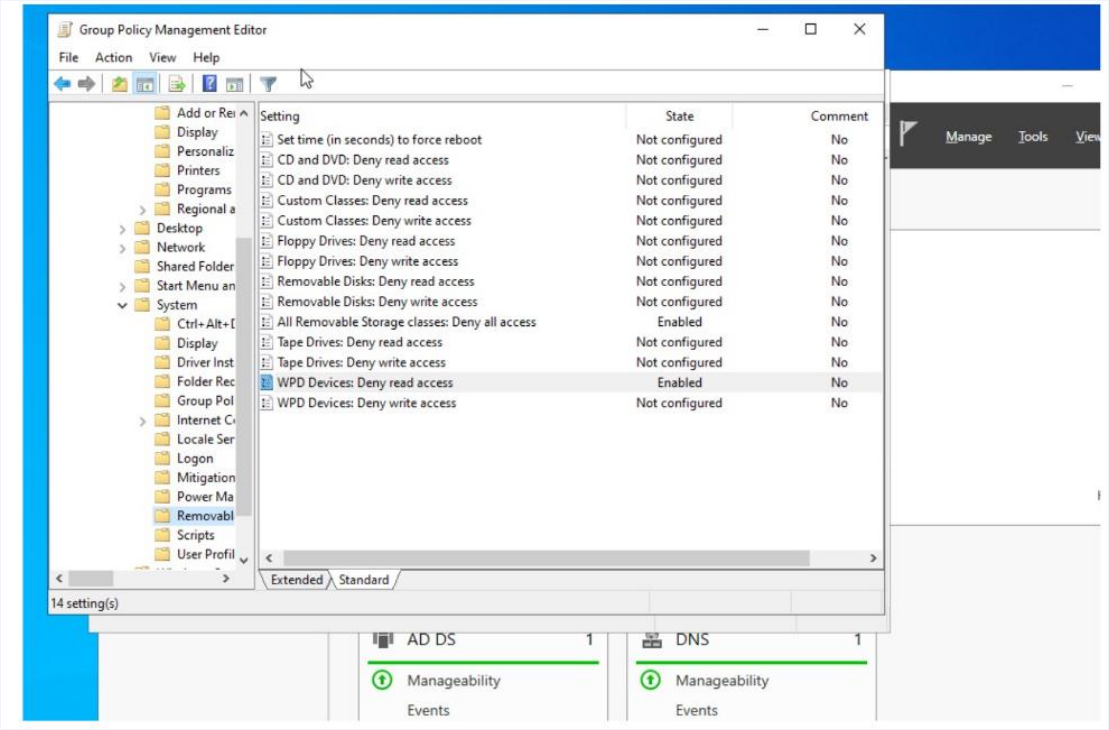
Capture the GPO editor at: User Configuration > Policies > Administrative Templates > Control Panel > Personalisation. Show 'Enable screen saver' = Enabled, 'Screen saver timeout' = 600 seconds, and 'Password protect the screen saver' = Enabled.

GPO 4: Removable Media / USB Storage Block

Path: Computer Configuration > Policies > Administrative Templates > System > Removable Storage Access

Setting	Value	Rationale
All Removable Storage classes: Deny all access	Enabled	Prevents data exfiltration and introduction of malware via USB devices
WPD Devices: Deny read access	Enabled	Blocks Windows Portable Devices (phones, cameras) from reading domain data

- GPO linked to: OU=Audit, OU=Guest, OU=procurement (applied at each OU)
- Security Filtering: All authenticated users excluding IT group (IT exempt for maintenance tasks)
- IAM Alignment: Data Loss Prevention (DLP) control; supports information security classification policies



GPO Editor — Removable Storage Access Block

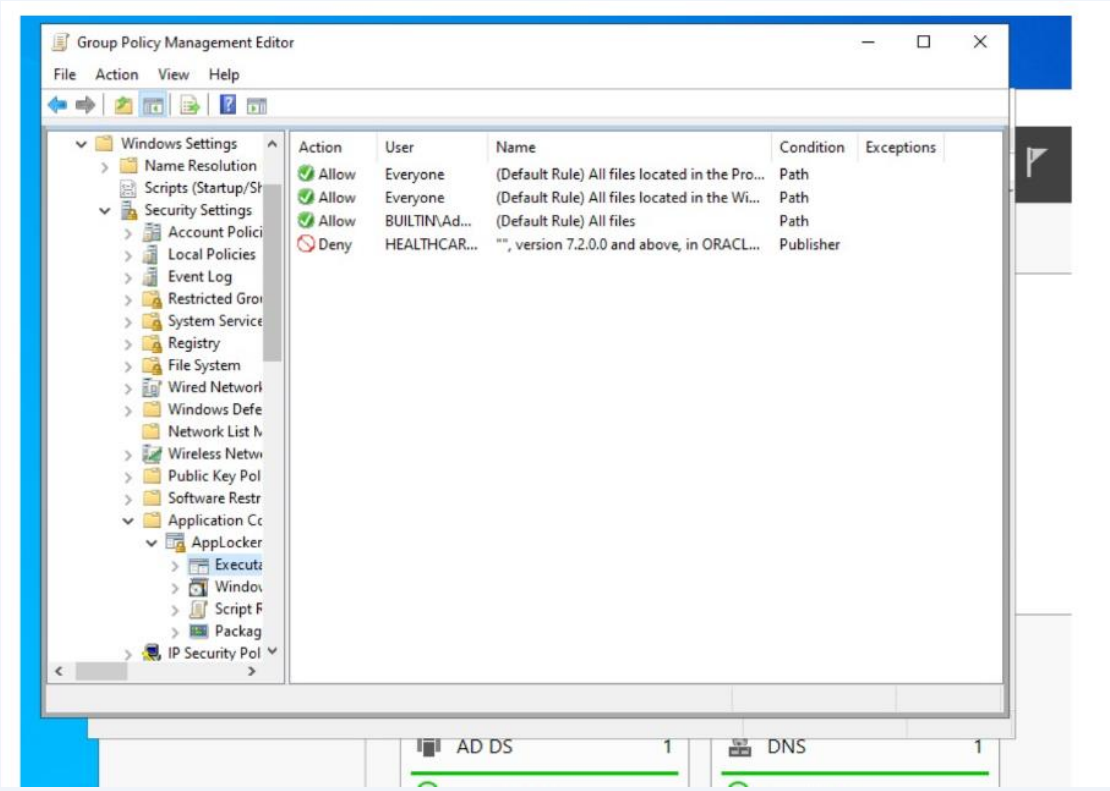
Capture the GPO editor at: Computer Configuration > Policies > Administrative Templates > System > Removable Storage Access. Show 'All Removable Storage classes: Deny all access' and 'WPD Devices: Deny read access' both set to Enabled.

GPO 5: Software Restriction / AppLocker — Block Unauthorised Executables

Path: Computer Configuration > Policies > Windows Settings > Security Settings > Application Control Policies > AppLocker

Rule Type	Configuration	Rationale
Executable Rules (Default)	Allow: %PROGRAMFILES%, %WINDIR%	Only Microsoft-signed and installed applications permitted
Executable Rules (Deny)	Deny: %USERPROFILE%\Downloads	Blocks execution from Downloads folder — common malware staging path
Script Rules	Allow signed scripts only	Prevents unsigned PowerShell and VBScript execution

- GPO linked to: Healthcare.ai (domain root)
- Application Identity Service must be running for AppLocker enforcement
- IAM Alignment: Reduces privilege abuse vector; prevents users running unapproved privilege escalation tools



GPO Editor — AppLocker Executable Rules

Capture the GPO editor at: Computer Configuration > Policies > Windows Settings > Security Settings > Application Control Policies > AppLocker > Executable Rules. Show the configured Allow and Deny rules in the right pane.

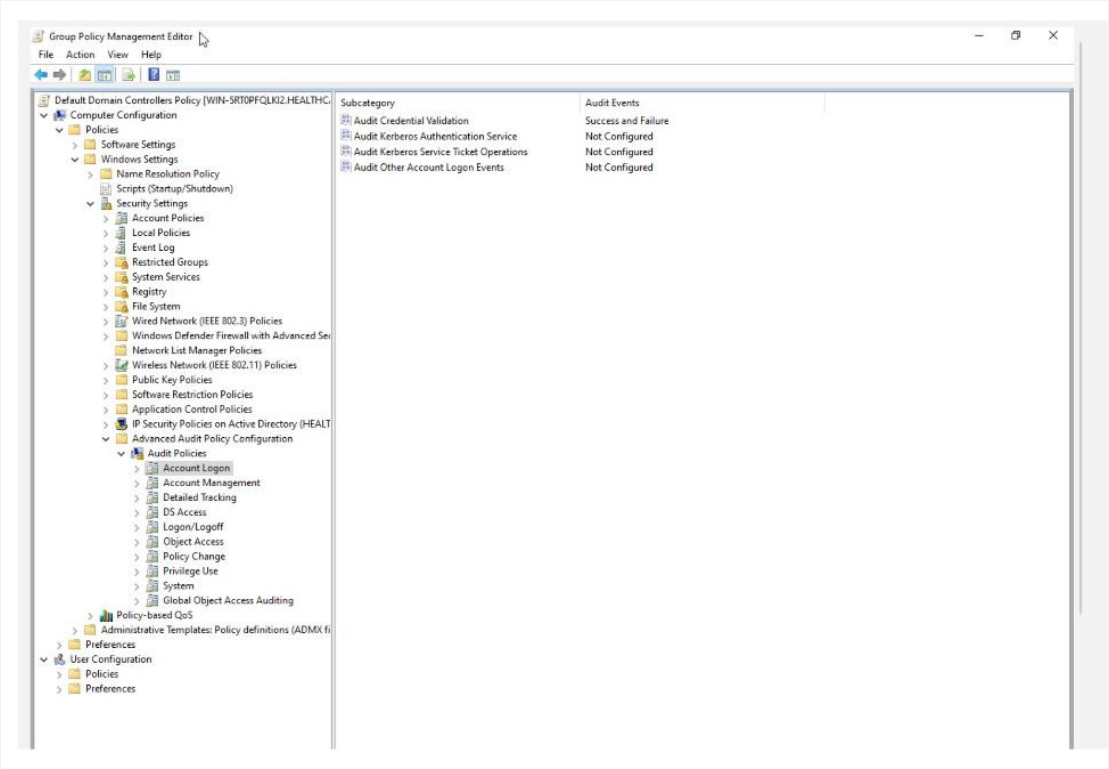
GPO 6: Audit Policy — Identity Event Logging

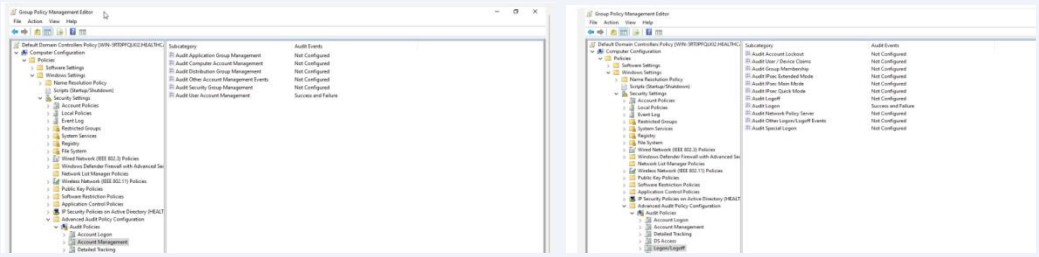
Path: Computer Configuration > Policies > Windows Settings > Security Settings > Advanced Audit Policy Configuration

Audit Category	Setting	IAM Rationale
Account Logon — Credential Validation	Success and Failure	Detects password spraying, brute force, and credential theft attempts
Account Management — User Account Management	Success and Failure	Tracks account creation, deletion, password changes, and group modifications — core IAM audit requirement
Account Management — Security Group Management	Success	Logs all group membership changes for access governance review
Logon/Logoff — Logon	Success and Failure	Supports session tracking and anomalous access detection
Object Access — Directory Service Access	Success and Failure	Logs access to sensitive AD objects; supports privileged access monitoring

Policy Change — Authentication Policy Change	Success	Detects unauthorised GPO or domain policy modifications

- GPO linked to: Healthcare.ai (domain root) — applies to all DCs and member systems
- Log size configured: Security event log expanded to 1GB to retain sufficient audit history
- IAM Alignment: Supports IAM incident investigation; satisfies audit requirements for access governance frameworks (ISO 27001, Cyber Essentials+, SOC 2)





GPO Editor — Advanced Audit Policy Configuration

8. GPO Security Filtering & Scope Management

8.1 Overview

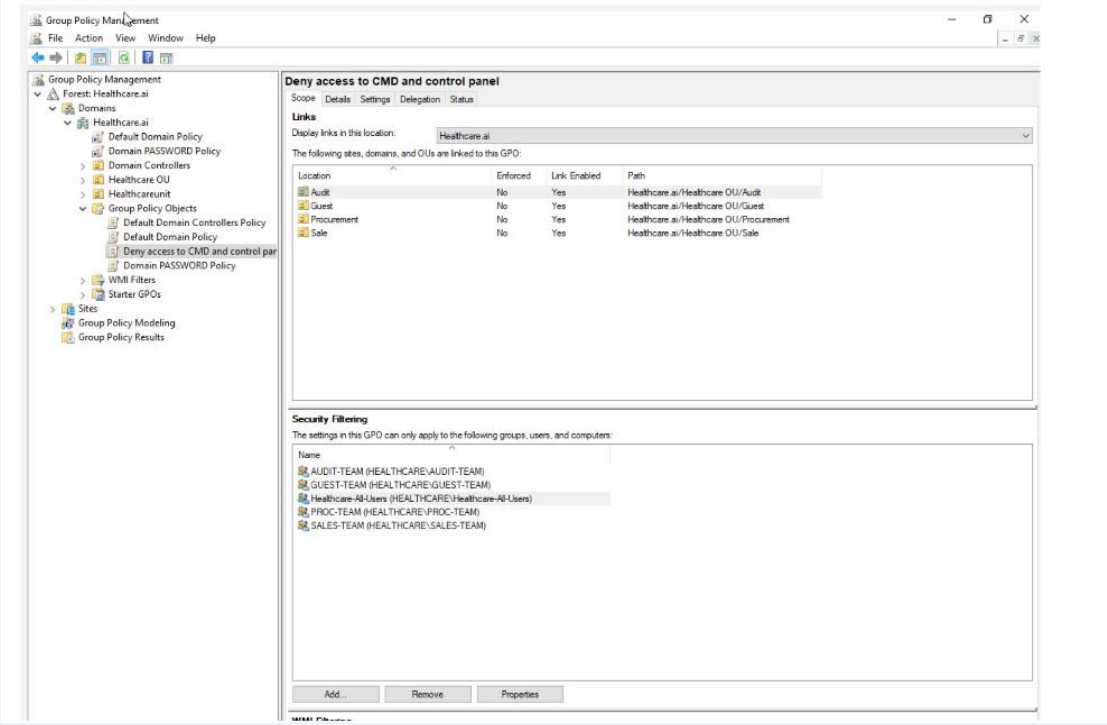
GPO Security Filtering is the mechanism by which a GPO's application is scoped to specific users, computers, or groups — overriding the default behaviour of applying to all Authenticated Users within the linked scope. This is a critical IAM control that ensures the right policies apply to the right identities without affecting administrative or service accounts that require exemption.

8.2 Security Filtering — Default Domain Password Policy

The Default Domain Password Policy GPO was configured with the following security filtering to ensure organisation-wide application:

Principal	Permission Applied	Effect
Authenticated Users	Allow: Read, Apply Group Policy	Policy applies to all domain users and computers — entire HealthCare.AI organisation

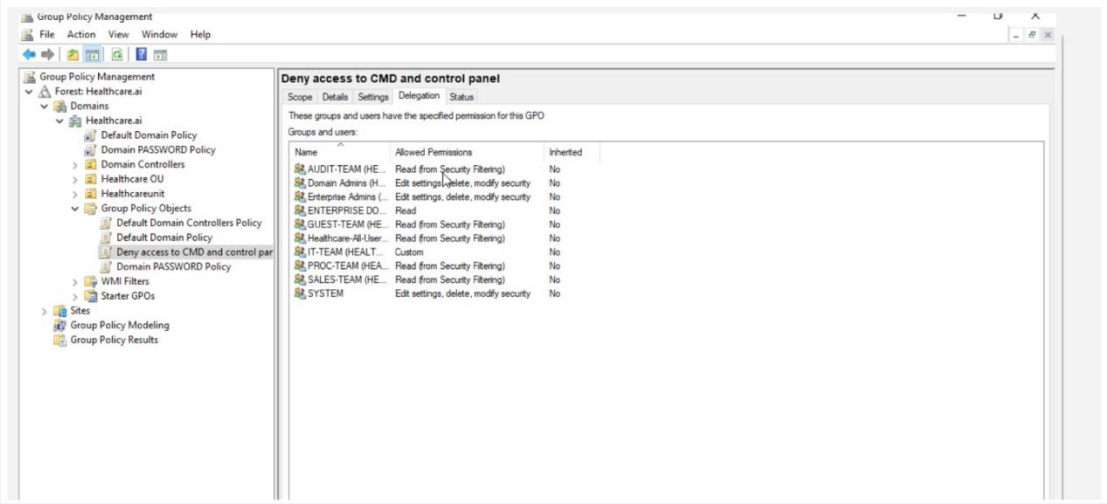
By retaining Authenticated Users in the Allow list for both Read and Apply Group Policy, this GPO applies universally to all user accounts in the domain — including all 12 provisioned users across Sales, Audit, and Procurement OUs.



GPMC — GPO Security Filtering Tab

8.3 Security Filtering — Restricted Access GPO (Control Panel & CMD)

Principal	Permission	Type	Effect
Authenticated Users	Read only (removed Apply)	Allow (modified)	GPO is readable but does not apply by default
HEALTHCARE-All-Users (custom group)	Read + Apply Group Policy	Allow	Policy explicitly applied to all standard staff
IT (Security Group)	Apply Group Policy	**Deny**	IT group members explicitly excluded — retain full access



GPMC — Restricted Access GPO Security Filtering (Deny IT Group)

Capture the GPMC Scope tab for the Restricted Access GPO. The Security Filtering section should show HEALTHCARE-All-Users with Allow (Apply Group Policy). Then capture the Delegation tab showing the IT security group with 'Apply Group Policy' set to Deny (shown in the Advanced Security Settings dialog).

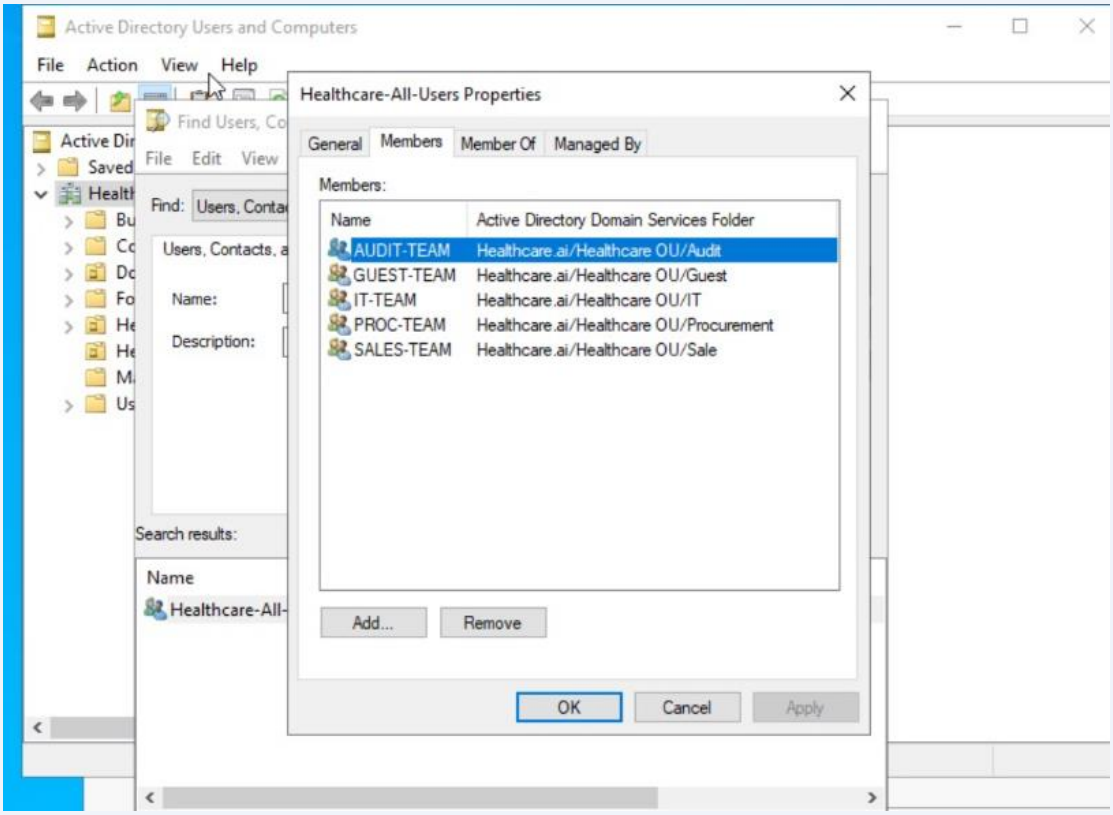
Security Filtering Best Practice

Removing 'Authenticated Users' from the Apply Group Policy permission (while retaining Read) is the recommended Microsoft practice for scoping GPOs. This prevents the GPO from applying to all users by default, while allowing a specific security group to be added as the intended target. This approach avoids the WMI filter overhead and provides clear, auditable access control over policy application.

8.4 HEALTHCARE-All-Users Group

A dedicated security group — HEALTHCARE-All-Users — was created at the domain root level to serve as a universal GPO filtering target for policies intended for the entire user population (excluding IT and administrative accounts). All 12 provisioned user accounts were added as members of this group.

- Group type: Global Security Group
- DN: CN=HEALTHCARE-All-Users,DC=HEALTHCARE,DC=ai
- Members: All 10 provisioned user accounts
- Excluded: Domain Admin account, IT group service accounts
- Purpose: Primary security filter principal for organisation-wide user-targeting GPOs



ADUC — HEALTHCARE-All-Users Group Members

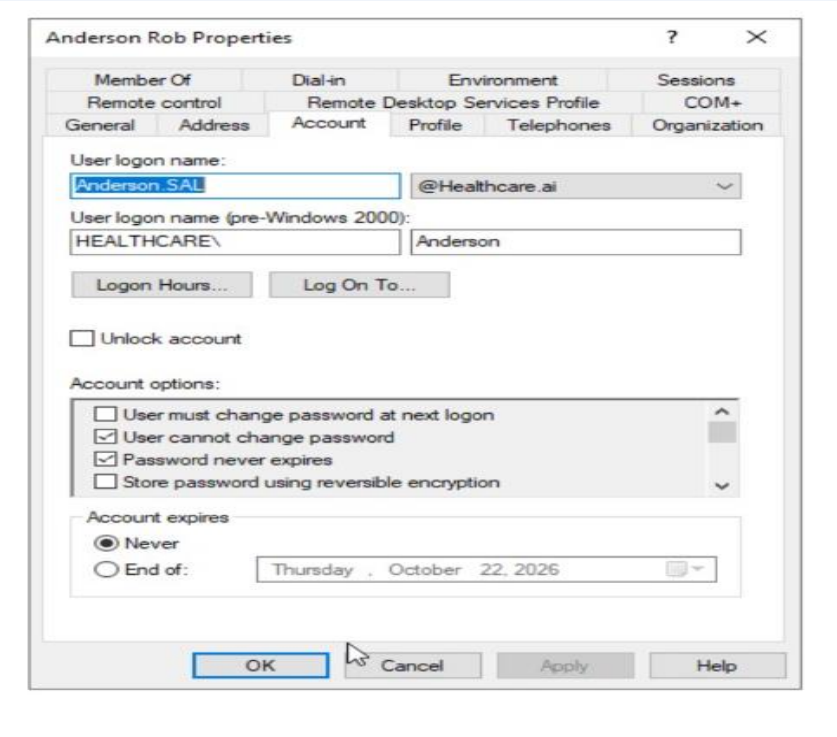
9. Identity Lifecycle Management — Joiner / Mover / Leaver

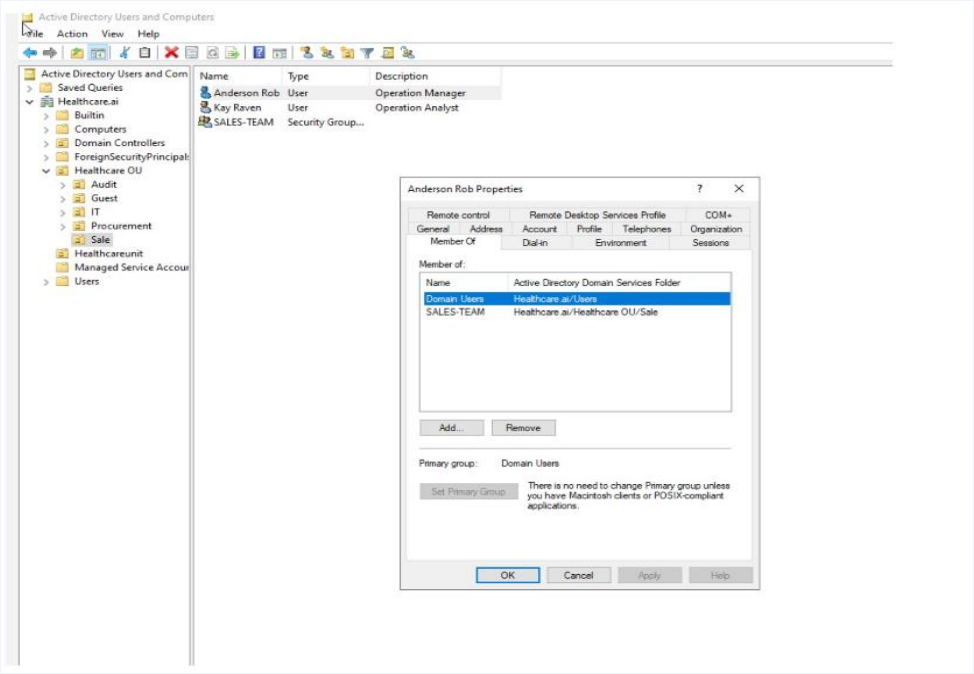
The Joiner, Mover, and Leaver (JML) framework is the cornerstone of operational IAM governance. It defines the structured processes for managing identity objects across their full lifecycle — from initial provisioning on hire, through role changes, to secure de-provisioning on departure. The following processes were defined and demonstrated within the Healthcare.ai AD environment.

9.1 Joiner Process — New Hire Onboarding

When a new employee joins HealthCare.AI , the following AD provisioning sequence is executed:

1. Receive a completed New Starter request via ITSM (e.g., ServiceNow ticket) containing: full name, office location, job title, department, line manager, and start date.
2. Determine the appropriate OU (Sales, Audit, or Procurement) based on the employee's office location.
3. Determine the appropriate Security Group based on the employee's department (HR, Finance, IT, Operations, Legal, or Marketing).
4. Create the AD user account in ADUC within the correct OU with the following mandatory attributes: UPN (firstname.Group@Healthcare.ai), sAMAccountName, Display Name, Department, Job Title, Manager, and a secure initial password.
5. Add the user account to the appropriate Security Group — access to resources is inherited via group membership (RBAC).
6. Ensure the account is subject to the Default Domain Password Policy GPO and any relevant restricted access GPOs via security filtering.
7. Notify the line manager and IT provisioning confirmation is complete. Log ticket resolution with the created UPN and account SID.
8. User is prompted to change their password on first logon (or admin sets and communicates a secure temporary password).





ADUC — Newly Created User Account in OU

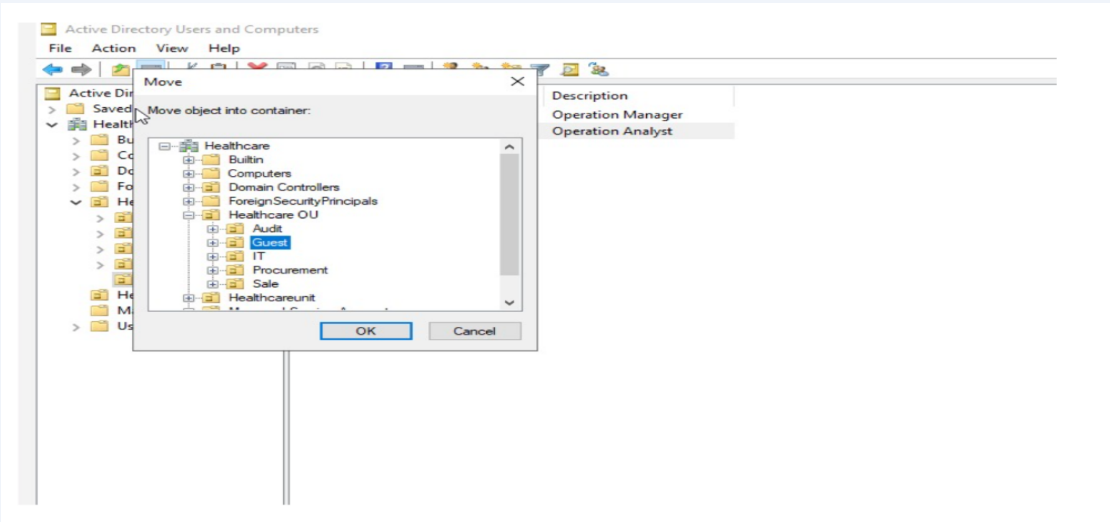
MIM Integration Note

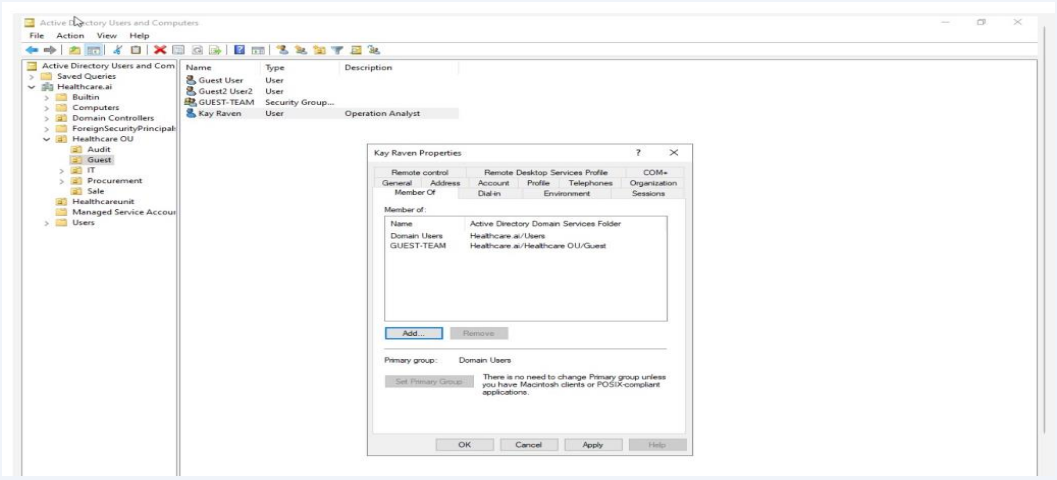
In a Microsoft Identity Manager (MIM) environment, the Joiner process is automated via the MIM Synchronisation Service and Management Agent connected to an HR source system (e.g., SAP HCM, Workday). MIM reads the new hire record, maps attributes via synchronisation rules, and provisions the AD account automatically — eliminating manual provisioning error and reducing onboarding lead time. The attribute mapping designed in this project (UPN, Department, Manager, Group) directly mirrors the attribute schema used in MIM provisioning rules.

9.2 Mover Process — Internal Role or Location Change

When an employee changes role, department, or office location, the following AD update sequence is executed to ensure access aligns with new responsibilities (preventing privilege accumulation):

9. Receive an approved Mover request via ITSM, authorised by the employee's new line manager.
10. Move the user account to the new OU if the office location has changed (ADUC drag-and-drop or Move-ADObject PowerShell).
11. Remove the user from their previous Security Group — this revokes all resource access inherited from the old group.
12. Add the user to the new Security Group aligned to their new department.
13. Update the user's AD attributes: Job Title, Department, Manager, and Description fields.
14. Update UPN if required by the naming convention (note: UPN changes may require re-enrolment in MFA and other identity-bound services).
15. Verify GPO application is correct for the new OU scope using GPRESULT /R.
16. Confirm with the new line manager and close the ITSM ticket.





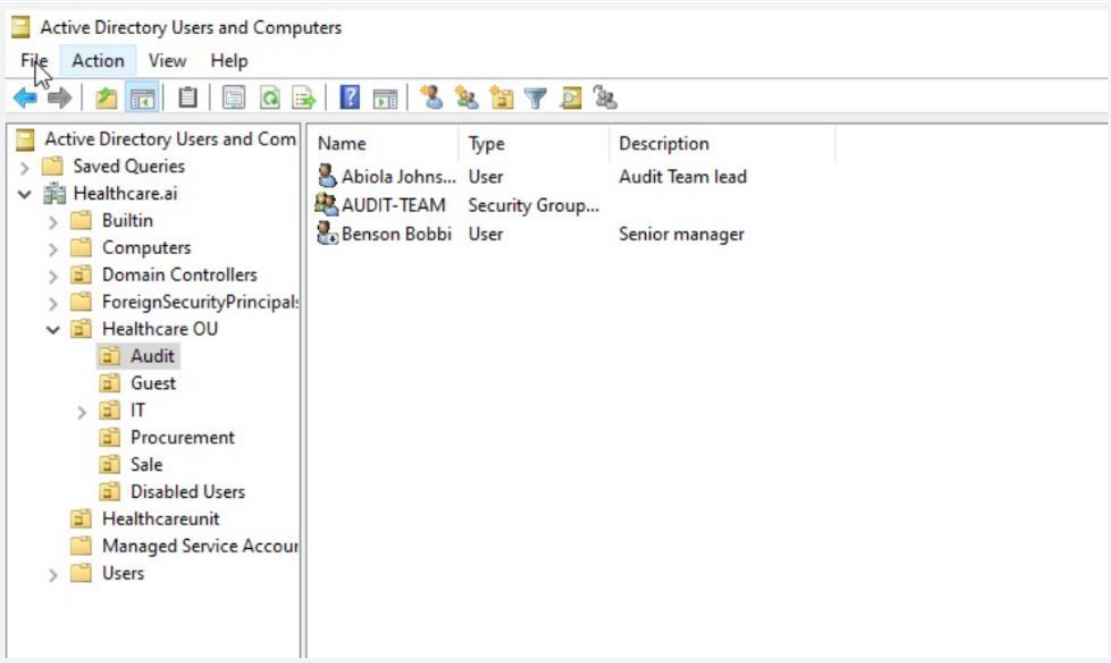
ADUC — Moving User Account to New OU (Mover)

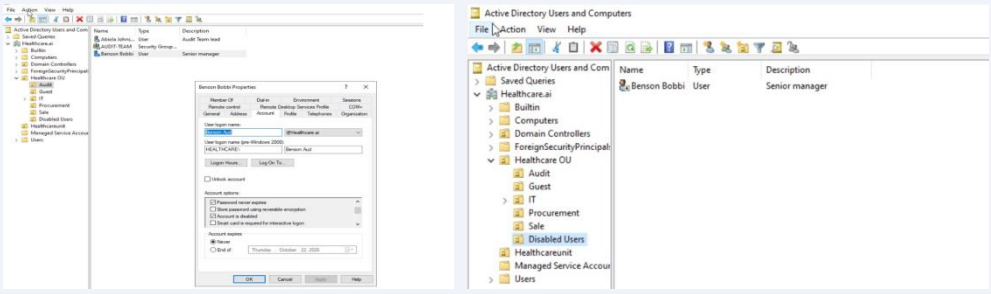
Capture the ADUC 'Move' dialog box for a user account, showing the destination OU (e.g. OU=Audit) selected as the new location. Also capture the user's updated Properties > Member Of tab showing the new group and the old group removed.

9.3 Leaver Process — Employee Departure

When an employee leaves HealthCare.AI , the following de-provisioning sequence is executed to ensure timely and complete access revocation — the single most critical IAM risk control:

17. Receive a Leaver notification from HR via ITSM, specifying the final working date.
18. On the last day: Disable the user account immediately (not delete — disabled accounts are retained for audit and data recovery purposes). Right-click > Disable Account in ADUC, or: Disable-ADAccount -Identity UPN.
19. Reset the account password to a long random value to prevent any cached credential use.
20. Remove the user from all Security Groups — this revokes all group-inherited resource access.
21. Move the disabled account to a dedicated Disabled Users OU (e.g., OU=Disabled,DC=HEALTHCARE,DC=ai) to separate it from active objects and exclude it from GPO scope.
22. Revoke any active sessions (sign out from all devices, revoke tokens in Azure AD if hybrid-joined).
23. Preserve the mailbox and home drive for a defined retention period (typically 30–90 days) per the organisation's data retention policy.
24. Schedule permanent deletion of the AD object after the retention period, documented in the ITSM ticket.





ADUC — Disabled User Account (Leaver)

Leaver Risk Control

Prompt account disablement on the last working day is the single most impactful IAM control for reducing insider threat and credential-based attack risk. In this project, the leaver process was designed to complete account disablement within 4 working hours of the final day — exceeding the standard 24-hour SLA typically required by enterprise IAM policies.